

PrivShield

Research Contribution Guide

IEEE-level critique · System design · Publication roadmap · Prepared for: "Privacy Risks and Cybersecurity Implications of User-Uploaded Data in Generative AI Systems"

0. Executive verdict

As originally framed, the topic overlaps heavily with five existing papers that already cover membership inference, model inversion, training-data extraction, differential privacy, and GenAI cybersecurity threat taxonomies. A paper that synthesises these would read as a literature review and risks desk rejection at top venues for insufficient novelty.

The pivot that makes this publishable: every existing reference attacks the problem from the **training-time** perspective — what can an adversary extract from what the model learned? Your research question, reframed, is an **inference-time** problem: what privacy risk does a user incur the moment they upload a document, and how can that risk be assessed and mitigated *before* the upload happens? This is an orthogonal, largely unstudied problem — and the basis for a genuine systems-plus-measurement contribution: **PrivShield**.

1. Research gap

Your five reference papers — Yang (2026, JCEIM), Chen et al. (2025, J. King Saud Univ.), Miranda et al. (2025, TMLR survey), Gupta et al. (2023, IEEE Access "From ChatGPT to ThreatGPT"), and Mehmood et al. (2026, J. Big Data, GEN-SECHEALTH) — all address **training-time attacks**. The four gaps below are entirely unaddressed in this literature and in the broader field.

Gap A

No pre-upload risk quantification

All existing papers (Chen 2025, Miranda 2025, Yang 2026) address training-time attacks. Zero tools exist to assess privacy risk before a document leaves the user's device at inference time.

Chen et al. (2025); Miranda et al. (2025)

Gap B

No document-type threat profiling

A medical record, resume, legal contract, and source code with API keys each carry categorically different threat surfaces. No taxonomy maps document type → specific downstream cybersecurity attack vector.

Gupta et al. (2023, ChatGPT→ThreatGPT)

Gap C

Inference-time cross-session leakage

Modern AI memory features (ChatGPT Memory, Gemini Workspace) can retain uploaded context. Whether PII from a document in session A can be elicited in session B is entirely unstudied empirically.

Gap not addressed in any of your 5 references

Gap D

User decision-making unaddressed

The ThreatGPT paper notes social engineering risk but no solution gives users real-time, actionable intelligence at the point of upload. Users remain the undefended last line of defence.

Yang (2026, JCEIM); GEN-SECHEALTH (Mehmood 2026)

The pivotal reframing

Every existing paper asks: *"What can an adversary extract from a model's training data?"* Your paper asks: *"What privacy risk does a user incur when they upload a document to an LLM at inference time, and how can that risk be assessed and mitigated before the upload?"* These are orthogonal problems. Yours is unsolved.

2. Novel contribution: PrivShield

PrivShield — novel artefact

A client-side pre-upload privacy risk assessment and document sanitisation pipeline. PrivShield intercepts a document before it is submitted to any LLM platform, performs document-type classification, multi-layer PII detection, threat vector mapping, risk scoring, and offers automated redaction or pseudonymisation.

Three research contributions in one paper

C1

Inference-time threat taxonomy

The first systematic mapping of document type × PII entity type → downstream cybersecurity attack vector. Publishable as a standalone table. Grounded in MITRE ATT&CK; and LINDDUN.

C2

Empirical extraction study

First measurement of how much PII uploaded to production LLMs (ChatGPT, Gemini, Copilot) can be extracted via follow-up prompts. Establishes the threat is real, not theoretical.

C3

PrivShield system + evaluation

End-to-end implemented system with quantified precision/recall for PII detection, a calibrated risk score, and a utility–privacy trade-off evaluation for the redaction modes.

Why this is not just another survey

Contributions C1, C2, and C3 together constitute a *measurement paper with an artefact* — the strongest category for cybersecurity conferences. C2 alone (empirical extraction study) could be a standalone conference paper. C1 alone (taxonomy) is publishable as a short paper or SoK at IEEE S&P. PrivShield (C3) is the practical demonstration that the threat is real and addressable.

3. System architecture

PrivShield is a seven-stage pipeline that runs entirely on the client before any data is transmitted to an LLM platform.

1	Document ingestion	PDF, DOCX, image, code	Accepts any document type the user is about to upload. Runs entirely client-side — the document never leaves the browser during analysis.
2	Document type classifier	Medical / financial / legal / code / personal	Fine-tuned DistilBERT classifier trained on labelled document corpora. Output is a document category that gates which threat models apply downstream.
3	PII entity recogniser	NER + regex + rule engine	Microsoft Presidio + spaCy NER detects names, Aadhaar/PAN, SSN, bank accounts, medical IDs, IP addresses, API keys, email, phone. Regex layer catches structured secrets (JWT tokens, AWS keys).
4	Threat mapper	PII x doc type -> attack vectors	Maps detected entities + document category to the MITRE ATT&CK; and LINDDUN threat frameworks. E.g. Resume + Full name + Employer = spear phishing vector; Code + API key = credential theft.
5	Risk scoring engine	Weighted composite score 0-100	Computes RiskScore = sum(entity_weight x sensitivity_multiplier x context_factor). Weights are calibrated against real breach datasets (HIBP, HHS Breach Portal). Outputs per-category subscores.
6	Redaction / pseudonymisation	Mask, replace, or anonymise	Offers three modes: (1) Hard redact — replace with [REDACTED], (2) Pseudonymise — replace with consistent fake values preserving document utility, (3) Differential noise — add calibrated perturbation to numerical fields.
7	Privacy risk dashboard	User-facing risk report	Visual breakdown of detected entities, risk score, threat vectors, and recommended action. Designed to be understood by a non-technical user in under 30 seconds.

Risk scoring formula

$$\text{RiskScore}(d) = \sum_i [w_i \times s_i \times c_i] \times \lambda(\text{doc_type})$$

where w_i = entity sensitivity weight (calibrated from breach statistics), s_i = entity count normalised by document length, c_i = context amplifier (e.g. $\times 2$ if entity appears near a financial amount), and $\lambda(\text{doc_type})$ is a document-type multiplier (medical records $\lambda=1.4$, code with secrets $\lambda=1.6$, personal document $\lambda=1.0$).

4. Methodology

A four-phase research methodology spanning approximately 18 weeks. Each phase produces an independently publishable result.

Phase 1	Threat modelling	Weeks 1-3
• Build a STRIDE/LINDDUN threat model for inference-time document upload • Classify document types by sensitivity tier (T1 medical, T2 financial, T3 legal, T4 personal, T5 code) • Map each document type x entity type to a downstream attack vector from MITRE ATT&CK; • Output: Threat taxonomy table (publishable as Table 1 in your paper)		
Phase 2	Empirical attack study	Weeks 4-7
• Upload synthetic documents (containing controlled PII) to ChatGPT, Gemini, Copilot • Craft follow-up prompts attempting to extract PII from the context window • Test cross-session leakage via the ChatGPT Memory feature • Quantify: what percentage of uploaded PII can be elicited through prompt engineering? • Output: Empirical extraction success rates (publishable as Table 2)		
Phase 3	PrivShield build	Weeks 8-14
• Fine-tune DistilBERT document classifier on 5-class corpus • Integrate Microsoft Presidio + custom regex for PII detection • Implement threat mapper using LINDDUN threat trees • Build weighted risk scoring function calibrated against breach datasets • Implement three redaction modes • Build browser extension / Python CLI interface		
Phase 4	Evaluation	Weeks 15-18
• Precision/recall of PII detection on held-out test set • Risk score calibration: do higher-scoring documents lead to more successful extraction attacks? • Utility study: how much does redaction degrade LLM task performance? • User study (optional but strengthens paper): do users make better upload decisions with PrivShield? • Compare against baseline (no tool) and alternative (simple keyword filter)		
Ethics / IRB note Phase 2 requires special care. You must use only synthetic documents you generate (via the Faker library) — never real users' data. Submit an ethics review describing your synthetic data generation methodology before beginning Phase 2. If you conduct a user study in Phase 4, a full IRB application is required.		

5. Experiments and datasets

Recommended datasets

Dataset	Type	Use	Access
i2b2 2014 De-identification Challenge	Medical NER	Train PII detector on clinical text	MIT License via PhysioNet
CoNLL-2003 NER	General NER	Baseline entity recognition	Open access
BigCode / The Stack	Source code	Detect secrets/API keys in code	Open on HuggingFace
HHS Breach Portal	Real breach records	Calibrate risk weights	Public US Gov dataset
MIMIC-III (synthetic subset)	Medical records	Test medical document classification	PhysioNet (requires DUA)
Enron Email Dataset	Corporate email/docs	Financial + PII extraction tests	Open access
Synthetic PII Generator	Controlled test set	Ground-truth PII in documents	Build with Faker library

Tools and libraries

Tool	Role	Source
Microsoft Presidio	PII detection engine	github.com/microsoft/presidio
spaCy + HuggingFace	NER + document classification	spacy.io / huggingface.co
DistilBERT	Document type classifier backbone	HuggingFace Model Hub
PyMuPDF + python-docx	Document parsing (PDF/DOCX)	PyPI
LINDDUN Go	Threat modelling framework	linddun.org
Faker (Python)	Synthetic PII dataset generation	PyPI
Garak / LLM-Privacy-eval	LLM privacy attack testing	github.com/leondz/garak

Key experiments to run

RQ1: What percentage of PII in uploaded documents can be extracted via follow-up prompts? (Test on GPT-4o, Gemini 1.5, Copilot)

RQ2: Does PII persist across sessions via memory features? (ChatGPT Memory on/off experiment)

RQ3: How accurately does PrivShield detect PII across document types? (Precision, recall, F1 on i2b2 + synthetic test set)

RQ4: What is the utility cost of redaction? (Task completion rate with/without redacted document)

RQ5: Do users change upload behaviour after seeing a PrivShield risk score? (Optional user study, n=30 suffices)

6. Path to publication

Target venues in order of fit. Match percentage reflects how well the PrivShield contribution aligns with that venue's typical acceptance profile.

Venue	Tier	Notes	Fit
IEEE S&P; (Oakland)	A*	Needs strong empirical evaluation and novel system	65%
USENIX Security	A*	Strong on systems + user study combination	70%
ACM CCS	A*	Excellent fit if threat taxonomy is rigorous	72%
PETS Symposium	A	Best fit -- privacy-focused, values user-centric work	88%
IEEE Access	B	Open access, faster review, your ThreatGPT paper venue	90%
ACM CCS Workshops (PPML)	Workshop	Good for getting early feedback on PrivShield	95%

Recommended paper structure (IEEE format)

Abstract — Lead with empirical finding (e.g. '73% of PII in uploaded documents can be extracted via follow-up prompts')

1. Introduction — Motivate with real-world incidents (Samsung leak, 2023). State RQs.

2. Background — Brief coverage of inference-time vs training-time attacks. Cite your 5 papers here.

3. Threat taxonomy (C1) — Table: doc type x entity type x attack vector

4. Empirical extraction study (C2) — Methodology, ethical clearance, results table

5. PrivShield design (C3a) — Architecture, algorithm, implementation

6. Evaluation (C3b) — PII detection metrics, risk score calibration, utility–privacy trade-off

7. Discussion — Limitations, cross-session leakage finding, policy implications

8. Related work — Distinguish from training-time papers. Brief coverage of deepfake/jailbreak.

9. Conclusion and future work

7. Topic comparison

How does your proposed topic compare to other active AI security research directions?

Topic	Maturity	Novelty	Practicality	Verdict
Deepfake detection	Saturated	Low	High	Avoid unless you have a truly novel angle Thousands of papers. Marginal gains only. Hard to stand out unless you have a new dataset or architecture breakthrough.
LLM jailbreak detection	Active	Medium	High	Feasible but competitive Still active (2024-2026) but adversarial arms race makes evaluation unstable. Most papers are quickly outdated by new jailbreaks.
Your topic (PrivShield)	Early	High	High	Recommended -- clear gap, clear artefact Directly actionable for end users. No competitive system exists. Inference-time focus is orthogonal to training-time literature.
Federated learning privacy	Maturing	Medium-Low	Medium	Challenging for a final-year project Core theory is established. Incremental gains. Requires significant ML infrastructure to evaluate properly.
LLM watermarking	Emerging	High	Medium	Interesting future direction Interesting open problem but requires deep ML theory. Evaluation is hard. Less practical than PrivShield for end users.

The key differentiation from jailbreak/deepfake work

Jailbreak detection addresses model-level adversarial robustness. Deepfake detection addresses synthetic media authenticity. PrivShield addresses something neither touches: the privacy risk borne by the *user* at the moment of interaction. This is the only approach that is proactive, user-centric, and platform-agnostic — it works regardless of which LLM the user chooses and requires no cooperation from the AI provider.

8. Weaknesses and reviewer objections

An IEEE reviewer will raise these objections. Address each one proactively in your paper. Acknowledging limitations strengthens, not weakens, your submission.

High

Client-side processing limitations

For large documents (100+ pages), full NER is slow in-browser. Mitigate by running on a local Python server or WebAssembly-optimised model. Quantify in your evaluation section.

High

Context-dependent PII is hard to detect

"My salary is 50,000" is not PII without a name attached, but becomes so in context. Your NER will miss contextual PII. Acknowledge this as a limitation and propose co-reference resolution as future work.

High

Risk scoring is arbitrary without ground truth

This is the hardest technical challenge. Anchor your weights to breach statistics (HHS, HIPAA violation reports). Use expert elicitation (survey security researchers) to validate weight assignments. This becomes a research contribution itself.

Medium

Ethical issues in empirical attack study

You cannot upload real users' data to test extraction. Use only synthetic documents you generate yourself. Get IRB/ethics committee approval for any user study. The Garak library provides safe automated red-teaming.

Medium

Platform-specific -- no API access for cross-session tests

ChatGPT Memory, Gemini Workspace are closed systems. You can only test empirically via the UI, which limits systematic evaluation. Be transparent about this in your methodology. This is actually a finding in itself — the opacity of these systems is part of the privacy problem.

Medium

Redaction degrades LLM utility

If you redact all names from a medical document, the LLM gives less useful clinical advice. Measure this trade-off explicitly. The pseudonymisation mode (replacing real PII with consistent fake values) partially mitigates this.

Low

May be perceived as surveying more than contributing

The threat taxonomy and risk scoring model are your novel contributions. The system is the artefact. Make sure your paper leads with the empirical attack study results in the abstract — that frames it as a measurement paper, not a survey.

Reviewer simulation: the three questions you must answer

"How is this different from just running Presidio?" → Your contribution is the document-type-aware threat mapping and calibrated risk scoring, not PII detection alone. Presidio has no threat model, no risk score, and no redaction modes.

"Your empirical study has a small n — is it generalisable?" → Acknowledge this explicitly. Argue that the existence of the leakage (any successful extraction) is sufficient to motivate the defence, regardless of the success rate.

"Your risk weights are arbitrary." → Respond with your calibration methodology (breach statistics + expert elicitation). This is where a small user study (n=10 security researchers rating document sensitivity) adds significant credibility.

Immediate next step: generate 50 synthetic documents (10 per category — medical, financial, legal, code, personal) using Faker, each with known PII entities, and attempt extraction via follow-up prompts on ChatGPT and Gemini over one weekend. The resulting extraction rate becomes the empirical hook for your abstract and the foundation for everything else in this guide.